

Procedimiento de Gestión de Incidentes de Seguridad Convergente

ISO/IEC 27001:2022 — Anexo A 5.24 a 5.28, A 6.8

Código de documento	SGSI-DOC-009	Versión	1.6
Estado	Revisión documental — pendiente de aprobación	Clasificación	Interna
Propietario	Jefe de seguridad — Atalaya GP SL		
Autor	El consultor (externo)		
Fecha de emisión	18/06/2026	Fecha de aprobación	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4		
Registro de aprobación	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.		

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	18/06/2026	El consultor	Emisión inicial; incorpora las lecciones del cuasi-incidente fundacional (RSC-001).
1.0	03/07/2026	Comité de Seguridad Convergente	Aprobación del documento.
1.1	24/07/2026	El consultor	Ampliación de la definición de evento (§2); alta de fuentes obligadas del cuaderno de indicios (§5).
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Retirada de la narración de versiones del cuerpo (§5); fuentes obligadas como norma vigente.
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	24/07/2026	El consultor	Reescritura de §1 y §5 conforme a la cadena de detección revisada. Ver decisiones.md §20.
1.3	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.4	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	23/08/2026	El consultor	Alta en §5 del protocolo de minimización penal para indicios que describan o identifiquen a una persona por posible conducta hostil o delictiva (art. 10 RGPD; art. 10 LOPDGDD), resolviendo la medida pendiente identificada en SGSI-DOC-011 §5.3 y SGSI-DOC-012 §3-4. Sin cambios en el resto del documento.
1.6	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.

1. Objeto y lección de origen

Define cómo se comunican, evalúan, responden y aprenden los eventos e incidentes de seguridad. Es deliberadamente un procedimiento de incidentes convergente: en el cuasi-incidente que originó el SGSI, los indicios existían en dos dominios —el

contacto digital persistente de un tercero con el hijo mayor y un vehículo reconocido en el perímetro de la finca— y llegaron a cruzarse, pero por la memoria de una persona concreta que estaba de servicio ese día y que sabía de quién era ese coche. No hubo proceso, ni canal, ni registro que hiciera repetible ese cruce, La detección observada se produjo en la semana diez; no está demostrado cuándo habría detectado el patrón el procedimiento. Este procedimiento existe para convertir ese azar en método.

2. Definiciones operativas

Evento: cualquier hecho observado con posible relevancia de seguridad, físico o digital: un correo extraño, un contacto insistente con un miembro de la familia, un vehículo repetido, un acceso fuera de horario, un fallo de una cámara. Se considera también evento la inejecución de un control previsto —una alarma no conectada al cierre, una ronda no realizada, una contrata presente fuera de su ventana horaria, un retraso reiterado del servicio de conducción—: el control existe y no operó, que a efectos de exposición equivale a que no exista (RSC-018, RSC-020, RSC-025).

Indicio: evento registrado que por sí solo no constituye incidente pero puede formar parte de un patrón.

Incidente: evento o conjunto de indicios que compromete o amenaza de forma verosímil la información, las personas o las instalaciones en alcance.

Incidente convergente: incidente cuya cadena cruza los dominios físico y digital. Se gestiona siempre de forma unificada, nunca como dos incidentes separados.

3. Comunicación: el canal único

Existe un único punto de comunicación de eventos e incidentes: el jefe de seguridad, con la Dirección General como alternativa. Cualquier medio vale para comunicar (llamada, mensaje, en persona); lo que no vale es callar o esperar.

- Sin represalia y sin ridículo: la comunicación de buena fe, incluida la de errores propios, no genera consecuencias negativas (SGSI-DOC-003, declaración del principal). Un evento comunicado de más cuesta un minuto; uno comunicado de menos costó este SGSI.
- La familia comunica a través de cualquier miembro del personal o directamente a la representante de la propiedad, que traslada al canal. A los menores se les da una instrucción única y simple en la sesión familiar: si alguien nuevo pregunta por la familia, la casa o los viajes, lo cuentas, no pasa nada.
- Los terceros (MSP, seguridad física, doméstico, agencias) tienen la obligación contractual de notificar en menos de 24 horas todo evento que afecte a Atalaya (DOC-006).

4. Clasificación y respuesta

S1 — Crítica: amenaza en curso contra personas, disposición patrimonial fraudulenta en ejecución, o compromiso de los sistemas de seguridad de la residencia. Respuesta: activación inmediata del jefe de seguridad y la Dirección General; Comité extraordinario en 24 h; valoración de denuncia y comunicación a autoridades por la Dirección General con asesoría legal.

S2 — Alta: compromiso confirmado de información Restringida o Confidencial; patrón de indicios que apunte a preparación de acción hostil. Respuesta: evaluación conjunta jefe de seguridad + Dirección General en el día; plan de contención; información a la representante de la propiedad.

S3 — Media: incidente acotado sin exposición de información Restringida. Respuesta: gestión por el propietario del ámbito afectado; registro y revisión en el Comité ordinario.

S4 — Baja / evento: eventos e indicios sin daño. Respuesta: registro en el cuaderno de indicios; sin más acción individual.

En incidentes con posible dimensión penal (extorsión, amenaza, intrusión), la prioridad de actuación es: personas, preservación de evidencias, contención. La recogida y preservación de evidencias —físicas y digitales— sigue el criterio de no alterar y documentar quién accede a qué, para no inutilizar una denuncia posterior (A 5.28).

5. El protocolo de correlación físico-digital

Pieza central del procedimiento y control comprometido en el objetivo O6:

- Cuaderno único de indicios: todos los eventos e indicios, físicos y digitales, se registran en un mismo registro (SGSI-REG-004), con fecha, fuente, descripción y dominio. Lo alimentan el jefe de seguridad, el MSP (alertas técnicas relevantes), el personal y la familia a través del canal.
- Revisión semanal de correlación: el jefe de seguridad revisa el cuaderno buscando patrones entre dominios: un contacto digital nuevo con un miembro de la familia + un vehículo repetido; un fallo de cámara + un acceso lógico anómalo al sistema de CCTV; una publicación con ubicación + una aproximación. Las correlaciones con verosimilitud se elevan a S2.

- Umbral deliberadamente bajo: tres indicios débiles conectados valen una evaluación. El coste de una falsa alarma interna es una reunión; el de una correlación no vista ya lo conocemos.
- La determinación de datos del art. 10 RGPD depende del contenido concreto y de que una persona sea identificada o identificable; la mera etiqueta «hostil» no determina por sí sola esa categoría. Cuando el contenido sea penal, no se incorpora a un archivo privado de investigación sin habilitación legal aplicable. La consulta jurídica y la EIPD no crean esa habilitación. La descripción funcional o la matrícula parcial tampoco garantizan anonimato. Se escala al Responsable del Tratamiento; la respuesta urgente a una amenaza y la comunicación necesaria a la autoridad competente no se demoran por un trámite ordinario de consulta. Se documentan necesidad, destinatario, contenido y fundamento de la comunicación.

Fuentes obligadas del cuaderno de indicios. Los documentos operativos derivan al cuaderno entradas concretas, que se relacionan aquí para que la fuente conste en el procedimiento que la consume y no solo en el que la origina:

- DOC-006 §7 (regla O4): presencia de contratas fuera de la ventana horaria acordada. Dominio: físico.
- DOC-006 §8 (regla N3): registro semanal de visitas no contractuales, cruzado con el resto de indicios. Dominio: físico/digital.
- DOC-008 §7 (regla T4): retraso reiterado del servicio de conducción sin causa acreditada. Dominio: físico.
- DOC-008 §5: aproximaciones o contactos anómalos detectados durante o después de un desplazamiento. Dominio: físico.
- DOC-007 §2 (regla R5): toda orden detenida por el freno de emergencia, con independencia de que resultara legítima. Dominio: digital.
- DOC-010 §2.2: hallazgos de la verificación técnica independiente con relevancia de correlación, derivados expresamente a este cuaderno además de a la auditoría. Dominio: digital.

La reconstrucción de REG-004 muestra cómo la revisión semanal podría adelantar una evaluación si los indicios estuvieran disponibles y se registraran en ese momento. La semana 4 es una hipótesis de ejercicio, no un resultado demostrado ni una garantía. Tres indicios conectados activan evaluación; la elevación a S2 requiere verosimilitud conforme a §4 y §5.

En cada revisión se documenta el descarte razonado de patrones inocuos y la corrección de entradas inexactas. Se comprueba que la finalidad sea de seguridad y no de vigilancia social o disciplinaria. La comunicación de indicios sobre menores a terceros exige necesidad, base jurídica y mínima información; la representación familiar no sustituye esa valoración ni impide comunicaciones urgentes legalmente necesarias. Estas precisiones desarrollan A.5.25/A.5.34 y no añaden una plataforma.

6. Cierre y aprendizaje

Todo incidente S1-S3 cierra con un informe breve del propietario: qué pasó, qué eslabones de qué escenario se materializaron, qué controles funcionaron y cuáles no, y qué cambia. El cierre obliga a re-evaluar los escenarios afectados del registro de riesgos (SGSI-DOC-004, sección 8) y, si procede, a proponer cambios de controles al Comité. Los incidentes y sus lecciones son insumo fijo de la revisión por la dirección y de la concienciación anual.

Anexo A. Trazabilidad

Sección	Control ISO/IEC 27001:2022 (Anexo A)
2, 3 — Definiciones y comunicación	5.24, 6.8
4 — Clasificación y respuesta	5.25, 5.26, 5.28
5 — Correlación físico-digital	5.25, 5.7 (inteligencia de amenazas)
5 — Minimización de datos del art. 10 RGPD (nuevo, v1.5)	5.31 (requisitos legales); RGPD art. 10; LOPDGDD art. 10; SGSI-DOC-011 §5.3; SGSI-DOC-012 §3-4
6 — Cierre y aprendizaje	5.27